

13 IAST on OpenMRS

You'll be running Contrast Community Edition to test OpenMRS.

Run OpenMRS

Download the standalone OpenMRS software from here:

<https://openmrs.org/download/>

Get the Reference Application 2.11.0, Standalone Edition. Unzip it somewhere and go to the unzipped directory.

Verify that you can run it successfully. Use this command line:

```
java -jar openmrs-standalone.jar -commandline
```

It takes a couple of minutes to fully start, and the first time you run it you will have to tell it you want demo mode. Verify you can reach the login page by using a URL like this (you'll need to change the VCM number):

<http://vcm-11732.vm.duke.edu:8081/openmrs-standalone/>

If it doesn't start up properly, check your Java version. I ended up using OpenJDK 8 (which you can get with `sudo apt-get install -y openjdk-8-jdk`). OpenJDK 11 did not work for me.

```
jk471@vcm-19861:~$ java -version
openjdk version "1.8.0_282"
OpenJDK Runtime Environment (build 1.8.0_282-8u282-b08-0ubuntu1~20.04-b08)
OpenJDK 64-Bit Server VM (build 25.282-b08, mixed mode)
```

You can login with admin / Admin123 and browse around the application, which is prepopulated with some data.

Sign Up for Contrast

Start here:

<https://www.contrastsecurity.com/contrast-community-edition>

Click **CREATE FREE ACCOUNT** and follow the steps to set up your account.

Continue following the steps to download the agent file *contrast.jar* and the YAML configuration file *contrast_security.yaml*. Follow the setup instructions.

Restart OpenMRS with the Contrast Agent

Shut down OpenMRS. At the console, you can type `exit`.

Edit the file *openmrs-standalone-runtime.properties*. At the end of the line about `vm_arguments`, add the following (with the correct path to the Contrast agent file):

```
-javaagent:/home/jk471/Downloads/contrast.jar
```

Now run OpenMRS again. As it starts, you will probably see some output when the Contrast agent starts up.

Do Some Stuff

You can view the output of the Contrast agent as it runs. In your home directory, use this command:

```
tail -f .contrast/contrast.log
```

Now navigate through the OpenMRS application in your browser. Click on links, perform searches, submit forms, and whatever else. As you work through the application, you'll see output from the Contrast agent in the log file.

In a perfect world, we would have a set of automated functional tests for OpenMRS. You could simply run through the normal suite of functional tests and the Contrast agent would report on whatever

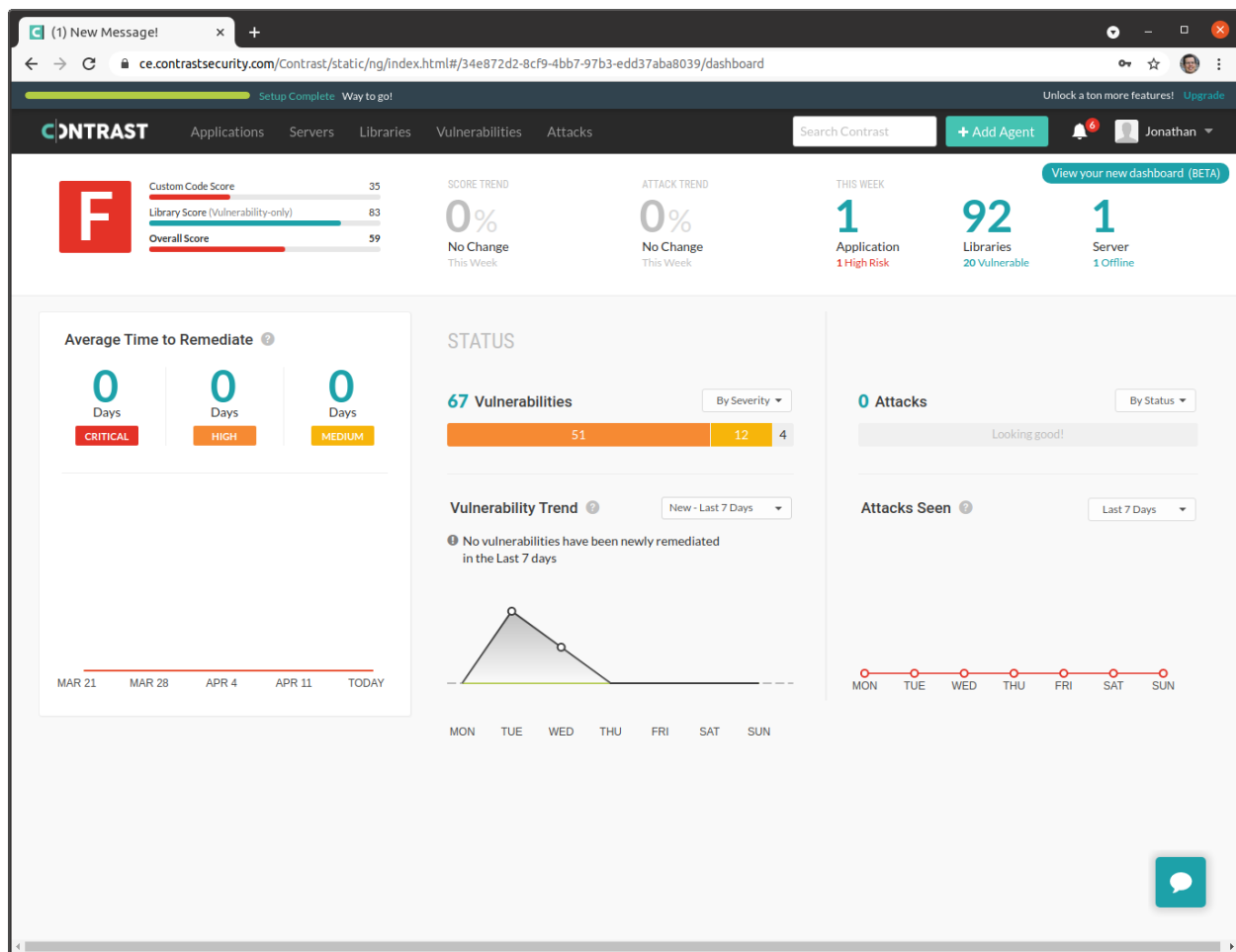
vulnerabilities it could observe. As a matter of fact, OpenMRS does have some tests available, but I've not figured out how to use them. For now, we'll have to content ourselves with some manual exploration in the application to populate some issues in Contrast.

You can use the Contrast web UI to see the findings. Contrast tells you about vulnerabilities, about the Bill of Materials, and other information. In addition, it will block certain types of malicious activity.

Submit

Submit a screen shot of the **Overview** tab of OpenMRS in the Contrast web interface.

Your screen shot should look something like this:



Make sure your screen shot includes the URL, the number of libraries and the number of vulnerabilities. Your numbers will be different, depending on how you probe the application.

In the results, find three vulnerabilities, with three different types. For each one, read the **Overview**, **Details**, and **How to Fix**. For each one, summarize in your own words why the vulnerability could be a problem, and how it can be fixed.